Technical Report: Permission-Based Security Testing Plan

Author: Surya Singh Chauhan

Intern ID: 2418

Organisation: RedKross Research Foundation

Assignment: Security Testing Plan

Report date: 20 October 2026

Submission deadline: 25 October 2026

Version: 1.0

Abstract

This report documents the design of a permission-based security testing plan for a demo web application. The work focuses on establishing written authorisation, defining scope and exclusions, selecting low-impact web security checks, recording evidence safely, and reporting findings with clear remediation guidance. The deliverable is a documented methodology and test-case register. No live target was tested while preparing this report; therefore, no vulnerability discovery, successful remediation, or test pass is claimed.

1. Objective

The objective is to provide a practical and repeatable plan that enables a tester and system owner to agree what may be tested, how tests should be conducted, how evidence will be protected, and how observations will be reported. The plan is designed for a local lab or explicitly authorised target.

2. Background research

Security testing is most useful when it is scoped, authorised, documented, and linked to remediation. NIST SP 800-115 describes planning and conducting technical security assessments and analysing results. The OWASP Web Security Testing Guide provides a structured set of web application testing categories and reporting guidance. OWASP Juice Shop is an intentionally insecure training application suitable for a self-managed lab.

The project applies these sources as guidance rather than claiming formal compliance or certification. The scope is intentionally limited to safe, non-destructive checks suitable for a student project.

3. Methodology

The work was organised into these design stages:

1. Review the assignment requirements and identify required outputs.
2. Define permission, scope, exclusions, test window, and stop conditions.
3. Design a staged workflow: prepare, validate scope, baseline, test, observe, analyse, report, close, and retest.
4. Build a test-case register covering scope validation, HTTPS/configuration observations, headers, authentication, sessions, access control, input validation, error handling, sensitive-data exposure, dependency review, logging/privacy, and retesting.
5. Create reusable authorisation, execution-log, evidence-index, and finding-report templates.
6. Document limitations and add authoritative references.

4. Tools and technologies

• Markdown for the test plan, report, and reusable templates.

• CSV for a structured test-case register that can be opened in a spreadsheet.

• SVG for a workflow diagram.

• A browser and developer tools may be used for low-impact observations during a future authorised execution.

• OWASP Juice Shop may be used as a local training target if the intern chooses to set it up.

• No security scanner or exploit tool was run to generate this package.

5. Work performed and deliverables

The package contains:

• A structured security testing plan.

• A scope and authorisation template.

• A 12-case candidate test register with objectives, methods, expected secure behaviour, risk and status fields.

• A test execution log template.

• A security finding/reporting template.

• An evidence handling guide.

• A workflow diagram.

• This technical report and a video explanation script.

The plan explicitly distinguishes candidate tests from executed tests. Each case starts as Not Run.

6. Findings and implementation results

Implementation result: The documentation package and templates have been prepared.

Testing result: No live or local target was tested during preparation of this report. No test case is marked as passed or failed. No actual vulnerability findings are asserted.

The CSV register can be reviewed for structure and opened in spreadsheet software. This is a document-structure check, not a security test of a web application.

7. Evaluation approach

When the plan is executed with approval, evaluation should record:

• Number of planned, run, blocked, and not-run cases.

• Findings by severity and confidence.

• Evidence completeness and redaction.

• Whether each finding has an owner and actionable remediation.

• Retest status for fixes.

• Any scope deviations or stop events.

Metrics should be calculated from actual execution records only. No numerical testing results are reported in this document because execution has not occurred.

8. Limitations

• The target application and environment have not been specified or tested.

• The test register is a baseline checklist, not exhaustive coverage.

• Results depend on application architecture, user roles, configuration, and approved scope.

• Manual checks can miss issues and may produce false positives.

• The plan does not include load testing, destructive exploitation, social engineering, or tests against third-party systems.

• The report does not claim certification, full OWASP coverage, or proof of absence of vulnerabilities.

9. Recommendations

1. Select a local training application or obtain written approval for a specific target.
2. Complete and sign the scope/authorisation form before any test execution.
3. Confirm a dedicated test window, synthetic accounts, backups where appropriate, and emergency contacts.
4. Run only relevant low-impact cases and record actual observations.
5. Review findings with the system owner and prioritise fixes by impact and context.
6. Retest only with authorisation and preserve a clear audit trail.
7. Keep sensitive evidence private and publish only redacted, non-sensitive artefacts.
8. Replace the video placeholder in the README with a real, accessible video link before submission.

10. Conclusion

The project provides a structured foundation for safe and permission-based web application security testing. Its main value is the connection between written scope, controlled testing, evidence handling, and practical reporting. The package is ready for review and for controlled execution after the target and authorisation details are completed. Actual testing outcomes remain unverified and must be recorded only after the tests are genuinely performed.

References

1. National Institute of Standards and Technology (NIST). *Technical Guide to Information Security Testing and Assessment*, SP 800-115. https://csrc.nist.gov/pubs/sp/800/115/final

2. OWASP Foundation. *Web Security Testing Guide — Stable*. https://owasp.org/www-project-web-security-testing-guide/stable/

3. OWASP Foundation. *OWASP Juice Shop*. https://owasp.org/projects/juice-shop

4. OWASP Developer Guide. *Juice Shop — Vulnerable Applications for Training*. https://devguide.owasp.org/en/07-training-education/01-vulnerable-apps/01-juice-shop/

Accessed: 20 October 2026.